

SOC 2 Readiness Assessment

Trust Services Criteria readiness review with prioritized remediation tracking

Entity	Sample Enterprise (fictional)
Prepared By	GRC Analyst Portfolio
Framework Basis	SOC 2 Trust Services Criteria
Document Type	Readiness Assessment Report
Version	1.0

Prepared by Gustavo do Carmo Lemes to practice evaluating control readiness against the SOC 2 Trust Services Criteria ahead of a formal examination.

1. Readiness Summary

This readiness assessment reviews a fictional organization's control environment against the SOC 2 Trust Services Criteria, with a primary focus on Security and selected Availability considerations. The current state shows a documented baseline, but evidence maturity and formal monitoring require strengthening before an external examination.

The most important readiness themes are evidence retention, formal control ownership, access review cadence, logging coverage, and change-management traceability.

2. Assessment Logic

Rating	Meaning
Implemented	Control exists and evidence is available
Partially Implemented	Control exists but evidence, scope, or consistency is insufficient
Planned	Improvement is identified but not yet operational
Not Implemented	No meaningful control or evidence is currently present

3. Representative Gaps

Criterion	Gap	Readiness Impact	Priority
CC6.1 Logical Access	MFA is incomplete for all users	High-risk access control weakness	Critical
CC7.2 Change Management	Change approvals are inconsistently documented	Weak audit evidence and oversight	High
CC7.3 Monitoring	Alerting use cases not formally defined	Delayed identification of suspicious activity	High
A1.2 Availability	Recovery testing not performed on a recurring schedule	Availability commitments may not be provable	Medium

4. 120-Day Readiness Plan

1. Assign named owners to all in-scope controls and evidence artifacts.
2. Require MFA for workforce, administrator, and remote-access identities.
3. Create a formal evidence library for access reviews, changes, incident response, and backups.
4. Define periodic monitoring reviews and retain records of investigations and follow-up actions.